Assignment 4: Securing Cloud Storage and Network Architecture

Scenario

You are a cloud security analyst for a fast-growing financial technology startup. The company has two critical infrastructure requirements that demand your security expertise.

First, the communications team needs to publish a public-facing security bulletin for their clients. You have been tasked with securely deploying this static asset using Amazon S3. You must ensure the storage bucket is properly hardened against unauthorized modification while allowing public read access, and you must implement data integrity controls and retention policies to meet industry compliance standards.

Second, the development team is deploying a sensitive internal analytics application. To protect this asset, you must architect a secure, isolated network boundary (VPC) that shields backend servers from external threats while safely permitting required administrative access.

In this assignment, you will complete 4 security-related tasks divided into two parts:

- **Part 1: Securing Public-Facing Cloud Storage Assets** (Task 1 and Task 2)
- **Part 2: Architecting a Secure, Segregated Cloud Network Boundary** (Task 3 and Task 4)

Learning Objectives

By the end of this assignment, you will be able to:

- Deploy a public-facing static asset securely using Amazon S3.
- Implement least-privilege access controls using bucket policies to allow public read access while preventing unauthorized data modification.
- Enforce data integrity and create tamper-evident backups using S3 versioning.
- Apply automated data retention and lifecycle management policies to meet compliance standards.
- Configure cross-region replication to ensure data redundancy and geographic disaster recovery.
- Architect a secure, isolated Virtual Private Cloud (VPC) network boundary.
- Deploy a Bastion Host and NAT Gateway to facilitate secure administrative access and outbound internet connectivity for private subnets.
- Implement defense-in-depth network traffic filtering using Network Access Control Lists (NACLs).

Environment Setup & AWS Account Configuration

This assignment is designed to be completed on Amazon Web Services (AWS), the industry-leading cloud platform. Utilizing a real-world cloud infrastructure provider gives you practical, hands-on experience with production-grade security tools, identity management, and network configurations that mirror industry standards.

To complete these tasks, you will need to create an AWS account. This assignment is strictly designed to utilize Free Tier eligible resources, meaning you can complete all tasks without incurring any financial charges. However, to guarantee you stay within the free limits, you must enable billing alerts immediately upon account creation and meticulously follow the Cleanup Instructions at the end of this document once your screenshots are captured.

Alternative Setup (Conditional Approval Only)

If you are legally or financially unable to create an AWS account (e.g., due to banking restrictions or lack of a valid payment method required for identity verification), you must contact your Open Learning Faculty Member immediately. You may be granted permission to use an open-source emulator like LocalStack to simulate the cloud environment locally. Note that while this allows you to complete the logical steps, it does not provide the authentic experience of interacting with a live cloud production environment.

How to Create Your AWS Account Safely

Follow these exact steps to set up your environment securely:

1. Go to aws.amazon.com and click **Create an AWS Account**.
2. We strongly recommend that you use a secondary or personal email address (not your main university or work email) to create the AWS account for this assignment. Once you have completed the assignment and submitted your work, we recommend that you close or delete the AWS account to avoid any unexpected charges. If you choose to keep the account, please be aware that you are fully responsible for its security and any costs incurred. AWS does not automatically limit your spending. If your account credentials are compromised, an attacker could use your account and generate significant charges for which you would be responsible.
3. Select the **Free Tier** option during registration.
4. Add a payment method (AWS requires a valid card for identity verification; you will not be charged for Free Tier usage).
5. Immediately turn on Multi-Factor Authentication (MFA) for the root account to protect it from unauthorized access.
6. Create a billing budget and automated alert so you are instantly notified by email if your projected charges exceed $0.00.

> **NOTE:** After completing the assignment and capturing all required screenshots, you must immediately follow the **Cleanup Instructions** located at the end of this document to tear down your resources and prevent any accidental charges.

Submission Method

Upload one single PDF or Word document containing all the required screenshots. Each screenshot must be clearly numbered and include a short caption describing what it shows.

Part 1: Securing Public-Facing Cloud Storage Assets

Total Marks: 40

What You Must Build

You will create and configure:

- An Amazon S3 bucket provisioned to securely host static web content.
- A publicly accessible security bulletin (using the provided sample index.html file).
- S3 Versioning enabled on the primary bucket to maintain data integrity and a tamper-evident audit trail.
- A data lifecycle policy containing two separate data retention rules for automated storage management.
- Cross-region replication to a secondary backup bucket in a different AWS Region for geographic disaster recovery.

Tasks

Task 1: Implement Least Privilege Access for Public Cloud Assets

Total Marks: 15

Scenario

The communications team has provided the HTML file (index.html) for the public security bulletin. Because misconfigured S3 buckets are a common attack vector, the Chief Information Security Officer (CISO) requires strict access controls. Your objective is to configure the bucket policy using the principle of least privilege, ensuring the asset is globally readable by the public, but strictly protected against unauthorized write, delete, or list operations.

Your Task

You must create and configure an Amazon S3 bucket to host the security bulletin securely, making it accessible to the public internet while applying proper security configurations at each step.

1. Create an S3 bucket in the US East (N. Virginia) `us-east-1` region.
2. Use a unique bucket name: For example, `seng-sec-bulletin-stdid` (replace `stdid` with your actual student ID).
3. Security Configuration Required: When creating the bucket, you must configure the public access settings correctly to intentionally allow public access.
4. Enable Static website hosting on the bucket.

5. Set the Index document to `index.html`.
   Note: This step allows the bucket to serve web content publicly. Make sure you only enable what is strictly necessary.
6. Upload the provided file (`index.html`) to the bucket.
7. Create a restrictive bucket policy that allows public read access to the website files only.
   - Use the bucket policy editor.
   - The policy must grant public (`*`) permission to read (`s3:GetObject`) the objects in the bucket.
   - *Security Configuration Required:* This is the primary control that makes the asset publicly accessible. You must only grant the absolute minimum permission needed (read-only access to objects). Do not grant unnecessary permissions such as write, delete, or list access to the public.
8. Note the Bucket website endpoint URL from the Static website hosting settings.
9. Verify functionality: Open the endpoint URL in a web browser. The security bulletin must load successfully without requiring any authentication or login.

Note: At this stage, focus only on making the bulletin publicly accessible in a secure and controlled way. Additional data protection features (such as versioning and lifecycle policies) will be implemented in Task 2.

Submission Requirements – Task 1 (15 Marks)

For Task 1, you must include the following screenshots in your submission document. Number them clearly and add a short caption for each one.

1. Screenshot 1: The S3 bucket creation settings showing it was configured correctly to host a publicly accessible website.
2. Screenshot 2: The Static website hosting settings clearly showing it is Enabled with index.html set as the Index document.
3. Screenshot 3: The Objects tab showing that the provided index.html file has been successfully uploaded to the bucket.
4. Screenshot 4: The Bucket Policy editor showing the configured JSON policy granting public read access.
5. Screenshot 5: Your web browser showing the security bulletin successfully loaded using the provided S3 Bucket website endpoint URL.

Marking Scheme for Teacher – Task 1 (Total: 15 Marks)

- Item 1 (3 marks): Full marks if the screenshot clearly shows both of these:
- “Block all public access” is unchecked, and ACLs are enabled.
- Item 2 (3 marks): Full marks if the screenshot clearly shows Static website hosting = Enabled and Index document = index.html.
- Item 3 (2 marks): Full marks if the screenshot clearly shows the index.html file uploaded in the bucket.

- Item 4 (4 marks): Full marks if the screenshot clearly shows a bucket policy with these two things: it grants s3:GetObject permission and the Principal is set to public (*).
  The screenshot shows a bucket policy similar to this example:

```
{
 "Version": "2012-10-17",
 "Statement": [
   {
     "Effect": "Allow",
     "Principal": "*",
     "Action": "s3:GetObject",
     "Resource": "arn:aws:s3:::your-bucket-name/*"
   }
 ]
}
```

- Item 5 (3 marks): Full marks if the screenshot clearly shows the website loaded in the browser using the Bucket website endpoint URL.

Task 2: Implement Data Integrity and Geographic Disaster Recovery

Total Marks: 25

Scenario

To comply with internal security policies and ransomware mitigation strategies, the S3 bucket must be resilient against data tampering and regional outages. You are required to implement versioning to provide a tamper-evident audit trail and allow rollback in the event of unauthorized modifications. Furthermore, you must establish cross-region replication for disaster recovery to ensure the bulletin remains available even if the primary AWS region experiences an outage.

They have asked you to add protection and backup features to the S3 bucket.

Your Task

You must configure three critical security and compliance features on your infrastructure: Versioning, Lifecycle Data Management, and Cross-Region Replication (CRR).

Note: As a strict requirement for CRR to function, versioning must be enabled on both the source and destination AWS S3 buckets.

- **Enable Versioning** on your primary S3 bucket. This tracks and copies every version of an object, creating a complete object history and preventing data loss from accidental overwrites.

- **Generate an audit trail:** Make a small, visible change to your local `index.html` file (e.g., change a heading or text color), and upload the modified file to your primary bucket.
- **Verify Versioning:** Navigate to the versions view in your bucket and confirm you can see at least two distinct versions of `index.html`.
- **Create a Lifecycle Policy** to manage storage costs and compliance. It must contain two separate rules (do not combine them):
    - **Rule 1:** Move *previous versions* of all objects to the S3 Standard-IA storage class after 30 days.
    - **Rule 2:** Permanently delete *previous versions* of all objects after 365 days.
- **Provision a Disaster Recovery (DR) bucket:** Create a second S3 bucket in a different AWS Region (e.g., `eu-west-1` or `ap-southeast-2`). Give it a unique name.
- **Enable Versioning** on this second (destination) bucket.
- **Establish Cross-Region Replication:** On your original (source) bucket, create a replication rule with the following configuration:
    - Replicate the entire bucket.
    - Create a new IAM role that grants S3 the necessary explicit permissions to perform the data transfer.
    - Choose **No** when asked about replicating existing objects (CRR only applies to new objects written after replication rules are configured).
- **Test the DR mechanism:** Make another small change to `index.html` and upload it to your source bucket.
- **Verify Replication:** Check your destination bucket and confirm that the newest version of the file has been automatically replicated. *Note: Replication happens asynchronously, so it may take a few moments to appear.*

Submission Requirements – Task 2 (25 Marks)

Submit the following screenshots for Task 2. Number them clearly.

1. Screenshot 6: The Properties tab of your primary S3 bucket showing that Versioning is enabled.
2. Screenshot 7: The Objects tab (with "Show versions" toggled on) showing at least two different versions of index.html.
3. Screenshot 8: The Lifecycle configuration clearly showing the two separate rules (move previous versions to Standard-IA after 30 days, and delete previous versions after 365 days).
4. Screenshot 9: The Properties tab of your second (destination) bucket in a different Region, showing that Versioning is enabled.
5. Screenshot 10: The Replication rules page on your source bucket showing the active replication rule.
6. Screenshot 11: The Objects tab of the destination bucket showing the replicated index.html file after your final test upload.

Marking Scheme for Teacher – Task 2 (Total: 25 Marks)

- **Item 1 (4 marks)**: Full marks if the screenshot clearly shows Versioning is enabled.
- **Item 2 (4 marks)**: Full marks if the screenshot clearly shows at least two versions of index.html in the Objects tab.
- **Item 3 (5 marks)**: Full marks if the screenshot clearly shows two separate lifecycle rules (one for moving to Standard-IA after 30 days, and one for deletion after 365 days).
- **Item 4 (4 marks)**: Full marks if the screenshot shows the second bucket in a different Region with Versioning enabled.
- **Item 5 (4 marks)**: Full marks if the screenshot clearly shows a replication rule created on the source bucket.
- **Item 6 (4 marks)**: Full marks if the screenshot shows the index.html file present in the destination bucket after replication.

Part 2: Architecting a Secure, Segregated Cloud Network Boundary

Total Marks: 60

What You Must Build

You will create and configure:

- A custom Virtual Private Cloud (VPC) establishing a secure network boundary.
- Segregated public and private subnets to isolate backend resources from direct internet exposure.
- An Internet Gateway and a NAT Gateway to securely manage inbound administrative traffic and outbound patch management traffic.
- A Bastion Host (Jump Box) deployed in the public subnet to act as a secure, monitored administrative entry point.
- An isolated backend server deployed in the private subnet, accessible only via SSH agent forwarding from the Bastion Host.
- Strict, stateful Security Groups enforcing least privilege access at the instance level.
- A custom stateless Network Access Control List (NACL) to explicitly block specific traffic at the subnet level as a defense-in-depth measure.

Task 3: Build a Secure Two-Tier Environment with Bastion Host and NAT Gateway

Total Marks: 35

Scenario

The development team is deploying a sensitive internal analytics application. To minimize the external attack surface, the backend application server must be strictly isolated from direct internet traffic by placing it in a private subnet.

To facilitate secure remote administration, you must engineer a secure entry point (a Bastion Host or "Jump Box") located in a public subnet. Additionally, the isolated backend server requires a secure outbound route to the internet via a Network Address Translation (NAT) Gateway. This allows the server to securely fetch critical operating system patches and security updates without ever exposing itself to inbound threats.

Your objective is to design and build this secure networking environment from the ground up using Amazon Virtual Private Cloud (VPC).

Your Task

Your objective is to engineer a secure, segregated network infrastructure that satisfies the following core architectural requirements:

- Place the critical backend server inside an isolated private subnet to eliminate direct exposure to inbound internet traffic.
- Establish a dedicated Bastion Host (Jump Box) within a public subnet to serve as the single, monitored point of entry for remote administration.
- Use SSH agent forwarding to authenticate your connection from your local computer to the Bastion Host, and then seamlessly pivot to the backend server without storing sensitive private keys on intermediate servers.
- Provision a NAT Gateway in the public subnet to grant the backend server outbound-only internet access for downloading critical vendor security patches, while completely blocking unauthorized inbound connection attempts.

By the end of this task, you must demonstrate a fully functional, layered defense topology where:

- The Bastion Host is accessible from the internet only via authorized administrative IP addresses.
- The backend server is entirely blocked from the public internet and accepts SSH traffic only when proxied through the Bastion Host.
- The backend server can successfully pull data from external repositories using the NAT Gateway.

Technical Requirements & Implementation Steps

You must build the environment using the exact names and settings below:

1. Create a VPC named Lab VPC with IPv4 CIDR block 10.0.0.0/16.
2. Create the following two subnets in the same Availability Zone (a):
    - Public Subnet with CIDR block 10.0.0.0/24
    - Private Subnet with CIDR block 10.0.1.0/24
3. Create an Internet Gateway and attach it to Lab VPC. Create a route table named Public Route Table, add a route to the Internet Gateway (0.0.0.0/0), and associate it with the Public Subnet.
4. Create a NAT Gateway named Lab NAT Gateway in the Public Subnet and allocate an Elastic IP to it. Then create a route table named Private Route Table, add a route to the NAT Gateway (0.0.0.0/0), and associate it with the Private Subnet.
5. Create a key pair named BastionKey and launch an EC2 instance with these settings:
    - Name: Bastion Host
    - AMI: Amazon Linux 2023
    - Instance type: t2.micro
    - Deploy it in the Public Subnet with a public IP address
    - Create a security group named Bastion Host SG that allows inbound SSH (port 22) only from your IP address
6. Create a key pair named PrivateKey and launch an EC2 instance with these settings:
    - Name: Private Instance
    - AMI: Amazon Linux 2023
    - Instance type: t2.micro
    - Deploy it in the Private Subnet (do not assign a public IP)

    - Create a security group named Private Instance SG that allows inbound SSH (port 22) only from the Bastion Host SG (Hint: search for and select the Bastion Host SG ID as the source, do not use an IP address).
7. Configure SSH agent forwarding on your local computer so you can connect from your machine to the Bastion Host, and then from the Bastion Host to the Private Instance without copying private keys.
8. Test the full connectivity:
    - Successfully SSH from your computer into the Bastion Host
    - From the Bastion Host, successfully SSH into the Private Instance
    - From the Private Instance, successfully run ping 8.8.8.8 (confirming internet access through the NAT Gateway)

Submission Requirements – Task 3 (VPC)

Submit the following screenshots for Task 3. Number them clearly and add short captions.

1. Screenshot 12: The VPC console showing Lab VPC with CIDR 10.0.0.0/16.
2. Screenshot 13: The Subnets list showing both Public Subnet (10.0.0.0/24) and Private Subnet (10.0.1.0/24) in the same Availability Zone.
3. Screenshot 14: The Internet Gateway attached to Lab VPC and the route table of the Public Subnet with a route 0.0.0.0/0 pointing to the Internet Gateway.
4. Screenshot 15: The Lab NAT Gateway created in the Public Subnet with an Elastic IP.
5. Screenshot 16: The Private Route Table showing a route 0.0.0.0/0 pointing to the NAT Gateway, and that it is associated with the Private Subnet.
6. Screenshot 17: The Bastion Host EC2 instance details showing: Name = Bastion Host, Placed in Public Subnet, Has a public IP, and Security group = Bastion Host SG.
7. Screenshot 18: The Bastion Host SG inbound rules showing SSH (port 22) allowed only from your IP address.
8. Screenshot 19: The Private Instance EC2 instance details showing: Name = Private Instance, Placed in Private Subnet, No public IP assigned, and Security group = Private Instance SG.
9. Screenshot 20: The Private Instance SG inbound rules showing SSH (port 22) allowed only from Bastion Host SG.
10. Screenshot 21: Your terminal showing a successful SSH connection chain: From your computer to Bastion Host, and from Bastion Host to Private Instance (using SSH agent forwarding).
11. Screenshot 22: The Private Instance terminal showing a successful ping 8.8.8.8.

Marking Scheme for Teacher – Task 3 (Total: 35 Marks)

- **Item 1 (2 marks)**: Full marks if **Lab VPC** with CIDR 10.0.0.0/16 is clearly shown.
- **Item 2 (3 marks)**: Full marks if both subnets with correct CIDRs and same AZ are shown.

- **Item 3 (4 marks)**: Full marks if Internet Gateway is attached and Public Subnet route table has 0.0.0.0/0 → IGW.
- **Item 4 (3 marks)**: Full marks if **Lab NAT Gateway** with Elastic IP in Public Subnet is shown.
- **Item 5 (4 marks)**: Full marks if **Private Route Table** has 0.0.0.0/0 → NAT Gateway and is attached to Private Subnet.
- **Item 6 (3 marks)**: Full marks if **Bastion Host** details are correct (name, public subnet, public IP, correct security group).
- **Item 7 (3 marks)**: Full marks if **Bastion Host SG** allows SSH only from your IP.
- **Item 8 (3 marks)**: Full marks if **Private Instance** details are correct (name, private subnet, no public IP, correct security group).
- **Item 9 (3 marks)**: Full marks if **Private Instance SG** allows SSH only from **Bastion Host SG**.
- **Item 10 (4 marks)**: Full marks if terminal shows successful SSH from local → Bastion Host → Private Instance using agent forwarding.
- **Item 11 (3 marks)**: Full marks if ping 8.8.8.8 succeeds from the Private Instance.

Total for Task 3 = 35 Marks

Task 4: Implement Defense in Depth Using Network Access Control Lists (NACLs)

Total Marks: 25

Scenario

Stateful Security Groups provide excellent instance-level protection, but true network security requires a Defense in Depth approach. The security operations team has requested stateless subnet-level traffic filtering to prevent potential lateral movement and block specific malicious traffic before it ever reaches the instances. You will deploy and configure custom Network ACLs to explicitly deny unauthorized traffic while permitting legitimate operations.

Your Task

You must create a test instance and configure a custom Network ACL to control traffic to and from the Private Subnet. You will then test that the Network ACL can block specific traffic while still allowing normal operations.

Requirements:

1. Launch a test EC2 instance in the Public Subnet with the following settings:
    - Name: Test Instance
    - AMI: Amazon Linux 2023
    - Instance type: t2.micro
    - Use the BastionKey key pair
    - Create a security group named Test SG that allows All ICMP – IPv4 traffic
    - Note the private IP address of this Test Instance

2. Create a custom Network ACL named Lab Network ACL for Lab VPC, and explicitly associate it with the Private Subnet.
3. Configure the Lab Network ACL with the following rules:
    - Allow all inbound and outbound traffic for the Private Subnet (this replaces the default deny-all rules).
    - Add a rule that denies ICMP traffic (ping) to the private IP address of the Test Instance (use /32 at the end of the IP, for example 10.0.0.XX/32). Make sure this deny rule has the lowest rule number so it is evaluated first.
4. Test the Network ACL:
    - From the Private Instance, first try to ping the private IP address of the Test Instance before you add the deny rule to your new Network ACL (the ping should succeed).
    - After applying the deny rule in the Network ACL, ping the same IP address again from the Private Instance. The ping should now fail (timeout).

Submission Requirements – Task 4 (VPC)

Submit the following screenshots for Task 4. Number them clearly.

1. Screenshot 23: The Test Instance details showing it is deployed in the Public Subnet with the security group Test SG that allows All ICMP – IPv4.
2. Screenshot 24: The private IP address of the Test Instance.
3. Screenshot 25: The custom Network ACL named Lab Network ACL.
4. Screenshot 26: The Lab Network ACL rules showing: All traffic is allowed for the Private Subnet, and a deny rule for ICMP traffic to the Test Instance private IP address (with /32) configured as the first rule.
5. Screenshot 27: The Private Instance terminal showing a successful ping to the Test Instance private IP before applying the deny rule.
6. Screenshot 28: The Private Instance terminal showing that the ping to the Test Instance private IP fails (times out) after the deny rule is applied in the Network ACL.

Marking Scheme for Teacher – Task 4 (Total: 25 Marks)

- **Item 1 (5 marks)**: Full marks if **Test Instance** is shown in Public Subnet with **Test SG** allowing All ICMP.
- **Item 2 (3 marks)**: Full marks if the private IP address of the Test Instance is clearly visible.
- **Item 3 (3 marks)**: Full marks if custom Network ACL named **Lab Network ACL** is shown.
- **Item 4 (5 marks)**: Full marks if the Network ACL rules clearly show allow-all traffic for Private Subnet **and** a deny ICMP rule to the Test Instance IP/32 as the first rule.
- **Item 5 (4 marks)**: Full marks if ping from Private Instance to Test Instance succeeds before the deny rule.
- **Item 6 (5 marks)**: Full marks if ping from Private Instance to Test Instance fails after the deny rule is applied.

Total for Task 4 = 25 Marks

Note for Teacher:

This task tests the student's ability to use Network ACLs as an additional layer of security. Focus on whether the deny rule is correctly configured and whether the before/after ping test works as expected.

Cleanup Instructions

After you finish all tasks and take the required screenshots, delete the resources in the following order to avoid unnecessary charges:

Part 1: Cloud Storage Cleanup

1. Empty both S3 buckets: Go to your primary bucket, click Empty, and follow the prompts to permanently delete all objects (including all previous versions). Repeat this for your secondary (destination) bucket.
2. Delete the primary S3 bucket.
3. Delete the secondary (destination) S3 bucket.
4. Delete the IAM role you created for Cross-Region Replication.

Part 2: Network & Compute Cleanup

5. Terminate all EC2 instances (Bastion Host, Private Instance, and Test Instance).
6. Delete the NAT Gateway (Lab NAT Gateway) and release its Elastic IP.
7. Delete the custom Network ACL (Lab Network ACL).
8. Delete the route tables you created (Public and Private Route Tables).
9. Delete both subnets (Public Subnet and Private Subnet).
10. Detach and delete the Internet Gateway.
11. Delete the VPC (Lab VPC).
12. Delete the key pairs you created (BastionKey and PrivateKey).

Final Verification After deleting everything, check the AWS Billing dashboard to confirm no resources are still running.

If you used the AWS CLI or downloaded AWS access keys during this assignment, go to the IAM console → Users → Security credentials, and delete any access keys you created. This is an important security practice to prevent unauthorized access to your AWS account.

Good Luck